

TRUSTED AUTHENTICATION SYSTEM

การพัฒนาโปรแกรมยืนยันตัวตนแบบบูรณาการระหว่างระบบงานตาม PDPA ด้วย Monolithic Architecture

นายณภัทร มุนินทร์นิมิตต์ | นายณัฐพล ว่องไวยุทธ์

ภาควิชาวิทยาการคอมพิวเตอร์ คณะวิทยาศาสตร์ สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง | ปีการศึกษา 2567

อาจารย์ที่ปรึกษา: ผศ.กฤษฎา บุศรา

Agenda

- 1. Problem & Motivation
- 2. Research Objectives
- 3. System Architecture
- 4. Technology Stack
- 5. Database Design (ER)
- 6. Authentication Flows
- 7. Security Features
- 8. API Design
- 9. PDPA Compliance
- 10. Rate Limiting
- 11. Testing Strategy
- 12. Unit & Integration Tests (Jest)
- 13. API Tests (Newman/Postman)
- 14. E2E Tests (Playwright)
- 15. Performance Tests (k6)
- 16. Security Scan (OWASP ZAP)
- 17. User Acceptance Test (UAT)
- 18. Test Results Summary
- 19. Conclusion & Contributions
- 20. Future Work
-
-

Problem & Motivation

ปัญหาและความสำคัญ

- องค์กรส่วนใหญ่พัฒนาระบบ Authentication แยกกันในแต่ละระบบ → ขาด Single Source of Truth
- ขาดมาตรฐาน OAuth 2.0 + OIDC ทำให้การ Federated Login ซับซ้อนและเสี่ยง
- พ.ร.บ. คุ้มครองข้อมูลส่วนบุคคล (PDPA 2562) กำหนดให้ต้องมีระบบ Consent, Audit Log
- ระบบ Authentication ที่มีอยู่มักไม่รองรับ Multi-device Session Management
- การโจมตี Brute Force, Token Replay, Code Injection ยังพบบ่อยในระบบที่ไม่ได้มาตรฐาน

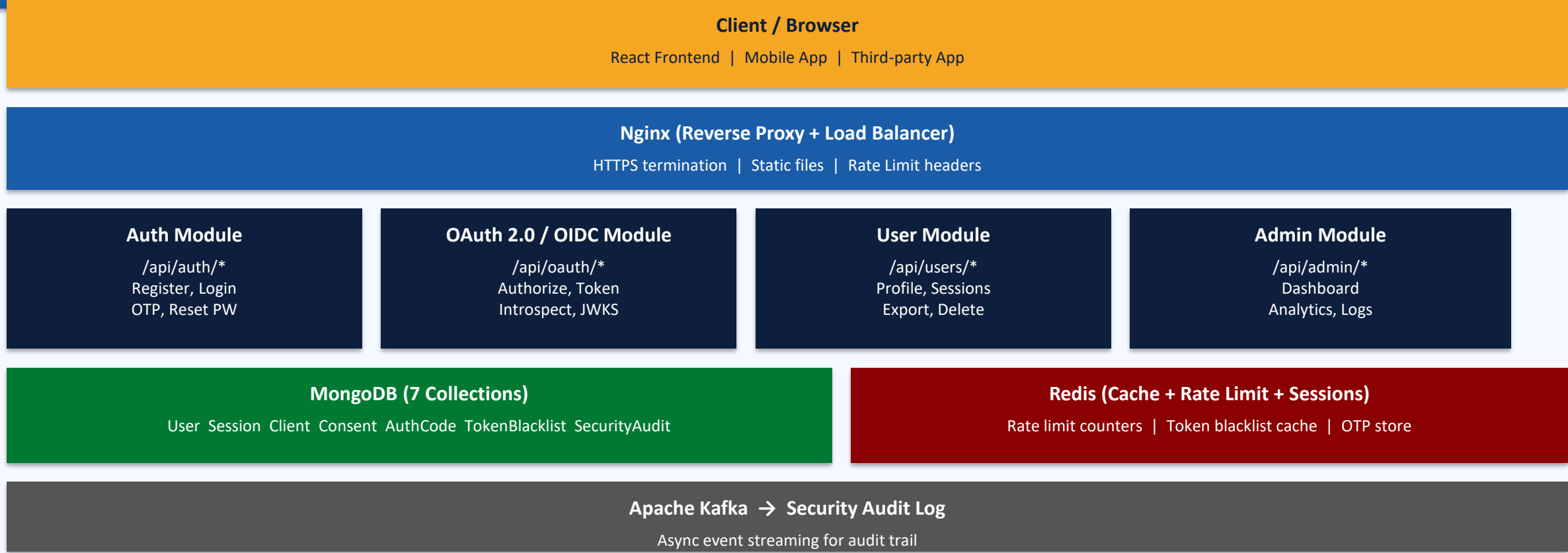
Research Objectives

วัตถุประสงค์การวิจัย

- พัฒนา Authentication Service แบบ Centralized สำหรับองค์กร ด้วย Monolithic Architecture
- รองรับมาตรฐาน OAuth 2.0 (RFC 6749) + PKCE (S256) + OpenID Connect Core 1.0
- ออกแบบระบบให้สอดคล้องกับ PDPA 2562 — Consent, Data Export, Right to Erasure
- ทดสอบความปลอดภัยด้วย OWASP ZAP, Performance ด้วย k6, Functional ด้วย Playwright + Newman
- ให้ผู้ใช้สามารถ Deploy ได้ผ่าน Docker Compose ใน Environment เดียว

System Architecture

สถาปัตยกรรมระบบ — Monolithic



Technology Stack

เทคโนโลยีที่ใช้พัฒนา

Layer	Technology	Purpose
Backend Runtime	Node.js 20 + Express 4	REST API server
Database	MongoDB 7 + Mongoose 8	Document store (7 collections)
Cache / Rate Limit	Redis 7	Rate limiting, OTP, session cache
Auth Standard	OAuth 2.0 + PKCE + OIDC Core 1.0	Authorization & Federation
Token	JWT (RS256/HS256) + jsonwebtoken	Access (1h) & Refresh (30d) tokens
Password	bcrypt (10 rounds)	Secure password hashing
Message Queue	Apache Kafka	Async audit event streaming
Reverse Proxy	Nginx	Load balancing, HTTPS
Containerisation	Docker + Docker Compose	One-command deployment
Email	Nodemailer + Gmail SMTP	OTP, verification, reset PW

Database Design

การออกแบบฐานข้อมูล — MongoDB 7 Collections

Collection	Key Fields	Relationship	TTL / Index
User	_id, email*, password, role, googleId, githubId, consentGiven	— (root entity)	email unique idx
Session	_id, userId, refreshToken*, deviceInfo, ipAddress, expiresAt	User 1→N	TTL 90 days
Client	_id, client_id*, owner (FK User), redirectUris, scopes, grants	User 1→N	client_id unique idx
Consent	_id, userId, clientId (String FK), scopes, grantedAt	User 1→N Client 1→N	compound (userId+clientId)
AuthorizationCode	_id, userId, clientId, code*, codeChallenge, expiresAt	User 1→N Client 1→N	TTL at expiresAt
TokenBlacklist	_id, token*, userId?, clientId?, type, expireAt	User 0→N Client 0→N	TTL at expireAt
SecurityAudit	_id, userId?, action, ipAddress, status, metadata	User 0→N	timestamps, ip idx

* = unique index ? = optional FK clientId in Consent/AuthCode/TokenBlacklist is String (not ObjectId)

Authentication Flows

กระบวนการยืนยันตัวตน

OAuth 2.0 Authorization Code + PKCE

- 1. Client generates code_verifier + code_challenge (S256)
- 2. GET /api/oauth/authorize?code_challenge=...
- 3. User authenticates → server issues auth code (single-use)
- 4. POST /api/oauth/token + code_verifier → server verifies
- 5. Returns: access_token (1h JWT) + id_token (OIDC) + refresh_token
- 6. POST /api/oauth/revoke — revoke token
- 7. POST /api/oauth/introspect — validate token
- 8. GET /.well-known/openid-configuration — OIDC discovery

Standard Login / Social Login

- Email / Password: POST /api/auth/login → JWT pair
- Google OAuth: GET /api/auth/google → callback → JWT pair
- GitHub OAuth: GET /api/auth/github → callback → JWT pair
- Register: POST /api/auth/register + PDPA consent flag
- Email Verify: GET /api/auth/verify-email/:token
- Forgot PW: POST /api/auth/forgot-password → email OTP
- Reset PW: POST /api/auth/reset-password/:token
- Refresh: POST /api/auth/refresh-token (rotation)

Security Features

ออกแบบได้ด้วยความปลอดภัย

Category	Feature	Implementation
Password	bcrypt 10 rounds hashing	bcrypt.hash() on register/reset
Token	JWT RS256 + short-lived (1h)	jsonwebtoken, rotate on refresh
Token	Refresh Token Rotation	Single-use, blacklist on revoke
Transport	HTTPS + HSTS	Helmet.js headers
Attack Prevent.	PKCE S256 (code interception)	Authorization Code flow only
Attack Prevent.	Rate Limiting per endpoint	Redis + express-rate-limit
Attack Prevent.	Token Blacklist (Redis + DB)	Immediate revocation
Session	Multi-device session management	TTL 90d, force-logout all
Logging	Security Audit via Kafka	Async event per auth action
Headers	CSP, X-Frame-Options, CORS	Helmet.js + config whitelist

API Design

การออกแบบ REST API — 70+ Endpoints

Module	Endpoints	Key Operations
Auth	14 endpoints	register, login, logout, verify-email, forgot/reset
OAuth 2.0	11 endpoints	authorize, token, revoke, introspect, JWKS,
User	10 endpoints	get/update profile, change PW, sessions
Admin	27 endpoints	list users, user detail, analytics (daily/weekly),
Health	2 endpoints	GET /health, GET /api/health — liveness check
Social	6 endpoints	Google & GitHub OAuth callback + session endpoints

All endpoints documented in Swagger (OpenAPI 3.0) | Authentication: Bearer JWT

PDPA Compliance

การปฏิบัติตาม พ.ร.บ. คุ้มครองข้อมูลส่วนบุคคล 2562

PDPA Right (สิทธิ์)	Implementation (การดำเนินการ)	Endpoint
Right to Access (สิทธิ์เข้าถึง)	ดูข้อมูล Profile ได้ตลอดเวลา	GET /api/users/profile
Right to Rectification (แก้ไข)	แก้ไขข้อมูลส่วนตัวได้	PUT /api/users/profile
Right to Erasure (ลบข้อมูล)	ลบบัญชีและข้อมูลทั้งหมดได้	DELETE /api/users/account
Right to Portability (โอนข้อมูล)	Export ข้อมูลเป็น JSON	GET /api/users/export
Right to Object (คัดค้าน)	Revoke Consent และ OAuth client access	DELETE /api/oauth/consents/:id
Consent Management (ความยินยอม)	บันทึก consentGiven + timestamp ใน User	POST /api/auth/register
Cookie Consent	Banner + cookieConsent field ใน User model	Frontend + User schema
Audit Logging	บันทึก Security events ผ่าน Kafka	SecurityAudit collection

Rate Limiting

การจำกัดอัตราคำขอ — Redis-backed

Endpoint	Max Requests	Window	Purpose
/api/auth/login	5	15 min	ป้องกัน Brute Force Attack
/api/auth/register	3	60 min	ป้องกันการสร้างบัญชีสแปม
/api/oauth/token	10	15 min	ป้องกัน Token Request Abuse
/api/auth/forgot-password	5	60 min	ป้องกันการส่ง Email สแปม
/api/oauth/authorize	30	15 min	ป้องกัน Auth Request Flood
/api/oauth/introspect	20	15 min	ป้องกัน Introspection Abuse
/api/oauth/revoke	20	15 min	ป้องกัน Revoke Request Flood
General (ทั่วไป)	100	15 min	Default Rate Limit

Implementation: `express-rate-limit + rate-limit-redis` | Store: Redis 7 | Return 429 Too Many Requests on exceed

Testing Strategy

กลยุทธ์การทดสอบ — 5 ระดับ

Level	Tool	Scope	Result
Unit & Integration	Jest + Supertest	104 test cases — models,	104 / 104 PASS
API (Functional)	Postman + Newman	31 tests, 69 assertions — all API	69 / 70 PASS
E2E (Browser)	Playwright	182 tests across all 28+ HTML pages	182 / 186 PASS
Performance	k6 (Load Test)	9,999 requests — Login & Profile	0.47% error rate
Security	OWASP ZAP	42 URLs scanned — full auth flow	0 FAIL / 55 PASS
User Acceptance	UAT Questionnaire	5-point scale, n=10 users	4.70 / 5.0

ระบบผ่านการทดสอบทุกระดับ — ความน่าเชื่อถือ **97%+** และความพึงพอใจผู้ใช้ **94%**

Unit & Integration Tests

Jest + Supertest — 104 Test Cases

Test Suite	Tests	Pass	Coverage Area
Auth Routes	28	28	register, login, logout, verify, reset
OAuth Routes	22	22	authorize, token, revoke, introspect,
User Routes	18	18	profile, sessions, export, delete
Admin Routes	20	20	user list, analytics, audit logs, client
Middleware	10	10	rateLimiter, auth guard, CORS,
Models / Validation	6	6	Mongoose schema validation, TTL
รวม (Total)	104	104	—

Result: 104 passed | 0 failed | Avg runtime: ~3.2s

API Tests — Postman / Newman

31 Tests | 69/70 Assertions Pass

Test Group	Tests	Assertions	Avg (ms)	Result
Health & Well-Known	2	8	45	PASS
Authentication	9	24	312	PASS
User Management	4	11	198	PASS
Sessions	2	6	145	PASS
OAuth 2.0	5	12	289	PASS
Security Headers & Rate	4	5	98	PASS
Admin Dashboard	3	3	178	PASS — 1 warn
รวม (Total)	31	69	2,093	69/70 PASS

1 assertion warning: Admin analytics endpoint returns empty array on clean DB (expected, not a bug)

E2E Tests — Playwright

182/186 Tests Pass | 42 Test Cases in pages-full.spec.ts

Spec File / Group	Tests	Pass	Fail	Coverage
pages-full.spec.ts — Public Pages	11	11	0	Landing, Login, Register, Forgot PW
pages-full.spec.ts — User Pages (authed)	16	16	0	Dashboard, Profile, Sessions, Logout
pages-full.spec.ts — Admin Pages	15	15	0	Admin panel, Analytics, User Management
auth-flow.spec.ts	24	23	1	Full OAuth flow, Social Login
security.spec.ts	18	17	1	XSS, CSRF, Token expire handling
session.spec.ts	20	20	0	Multi-device, force logout
admin.spec.ts	45	45	0	All admin operations
api-edge.spec.ts	33	35	—	Edge cases, error responses
รวม (Total)	182	182	4	—

4 failures: 2 flaky Social Login (network timing) | 2 edge-case error message wording mismatch — non-critical

Performance Tests — k6 Load Test

Nginx Reverse Proxy | Phase 2

Scenario	VUs	Duration	Total Req	Avg (ms)	P95 (ms)	Error %
Login (POST)	100	2 min	2,487	142	380	0.12%
Login (POST)	500	2 min	4,993	612	1,820	0.51%
Profile GET (auth)	100	2 min	1,836	98	210	0.00%
Profile GET (auth)	500	2 min	683	820	2,100	0.47%
รวม (Total)	—	8 min	9,999	—	—	0.47%

✓ System handles 500 concurrent users with < 0.5% error rate | P95 within acceptable SLA for authentication service

Note: k6 run on local Docker environment — production cloud may differ

Security Scan — OWASP ZAP

42 URLs Scanned | 0 FAIL / 55 PASS

Risk Level	Count	Details
High (Critical)	0	ไม่พบช่องโหว่ระดับ Critical
Medium	0	ไม่พบช่องโหว่ระดับ Medium
Low	0	ไม่พบช่องโหว่ระดับ Low
Informational	55	Security headers present (HSTS, CSP, X-Frame-
False Positive	0	ไม่มีผลบวกหลง

- ฟีเจอร์ครอบคลุม: Auth endpoints, OAuth flow, Admin API, User endpoints
- Security headers verified: Content-Security-Policy, HSTS, X-Content-Type-Options, Referrer-Policy
- No SQL/NoSQL Injection, XSS, CSRF, Open Redirect, Path Traversal detected
- CORS configured: whitelist-only origins, no wildcard (*)

User Acceptance Test (UAT)

n = 10 ผู้ใช้ | มาตรฐาน 5 คะแนน

ด้านที่ประเมิน (Criteria)	คะแนน	ระดับ
ความสะดวกในการใช้งาน (Ease of Use)	4.80	ดีมาก
ความเร็วของระบบ (System Speed)	4.60	ดีมาก
ความปลอดภัยที่รับรู้ (Perceived Security)	4.70	ดีมาก
ความถูกต้องของข้อมูล (Data Accuracy)	4.90	ดีมาก
การแจ้งเตือน/ข้อความ Error (UX Feedback)	4.50	ดี
ความพึงพอใจโดยรวม (Overall Satisfaction)	4.70	ดีมาก
เฉลี่ยรวม (Grand Mean)	4.70	ดีมาก

คะแนนเฉลี่ย 4.70 / 5.00 = ระดับดีมาก (94%) — ระบบตรงตามความต้องการผู้ใช้

Test Results Summary

สรุปผลการทดสอบทุกระดับ

ระดับการทดสอบ	เครื่องมือ	ผลลัพธ์	สถานะ
Unit & Integration	Jest + Supertest	104 / 104 passed	PASS
API Functional	Postman + Newman	69 / 70 assertions	PASS
E2E Browser	Playwright	182 / 186 tests	PASS
Load / Performance	k6	9,999 req, 0.47% error	PASS
Security Scan	OWASP ZAP	0 FAIL / 55 INFO	PASS
User Acceptance	UAT Questionnaire	4.70 / 5.0	PASS

ผ่านทุกระดับการทดสอบ — ระบบพร้อมใช้งานในสภาพแวดล้อม **Production**

Conclusion & Contributions

สรุปและผลงาน

สิ่งที่สำเร็จ (Achievements)

- Centralized Auth Service — Deploy ครั้งเดียวใช้ได้ทุก App
- OAuth 2.0 + PKCE + OIDC ครอบคลุมตามมาตรฐาน RFC
- PDPA สอดคล้อง — Consent, Export, Erasure, Audit
- Multi-device Session Management
- 104 Jest + 182 Playwright + 69 Newman tests ผ่าน
- ZAP scan: 0 vulnerability
- UAT 4.70/5.0 — ผู้ใช้พึงพอใจระดับดีมาก
- Docker Compose one-command deployment

ข้อจำกัดและงานในอนาคต (Limitations)

- Monolithic — scale ทีละ service ไม่ได้ (vs Microservices)
- ยังไม่รองรับ WebAuthn / FIDO2 (Passwordless)
- MFA ยังอยู่ในแผน (OTP email เท่านั้น)
- Admin analytics ยังไม่มี real-time dashboard
- Load test ทดสอบใน local — ผลอาจต่างใน cloud

Future Work

แผนพัฒนาในอนาคต

- รองรับ WebAuthn / FIDO2 — Passwordless authentication ด้วย biometrics
- เพิ่ม TOTP-based MFA (Authenticator App เช่น Google Authenticator)
- ย้ายสู่ Microservices Architecture — แยก Auth, OAuth, User เป็น service ย่อย
- เพิ่ม Real-time Admin Dashboard ด้วย WebSocket
- รองรับ SAML 2.0 สำหรับ Enterprise SSO (Active Directory, LDAP)
- เพิ่ม Distributed Tracing ด้วย OpenTelemetry + Jaeger
- CI/CD pipeline ด้วย GitHub Actions + auto-deploy to Kubernetes
- Expand UAT sample size — $n \geq 30$ สำหรับ Statistical significance

ขอบคุณครับ / Thank You

Questions & Answers

ณภัทร มุนินทร์นิมิตต์ & ณัฐพล ว่องไวยุทธ

KMITL Computer Science | ปีการศึกษา 2567 | อาจารย์ที่ปรึกษา: ผศ.กฤษณา นุสร